

SECURITY ASSESSMENT



Accretion

Provided by Accretion Labs Pte Ltd. for Solana Foundation
September 08, 2025

Solana Foundation

A25SFR1

AUDITORS

Role	Name
Lead Auditor	Robert Reith (robert@accretion.xyz)
Auditor	Mahdi Rostami (mahdi@accretion.xyz)

CLIENT

Solana Foundation (<https://squads.so>) engaged Accretion Labs to conduct a security assessment for an external signature program implemented by Squads. This program allows users to authenticate on-chain actions using authentication methods such as passkeys, webauthn, and potentially others.

ENGAGEMENT TIMELINE



AUDITED CODE

Program 1

ProgramID: ExtSgUPtP3JyKUysFw2S5fpL5fWfUPzGUQLd2bTwftXN

Repository: <https://github.com/Squads-Grid/external-signature-program>

ASSESSMENT

The security assessment of the external signature program revealed an exceptionally well-architected implementation with no identified security vulnerabilities during our comprehensive review.

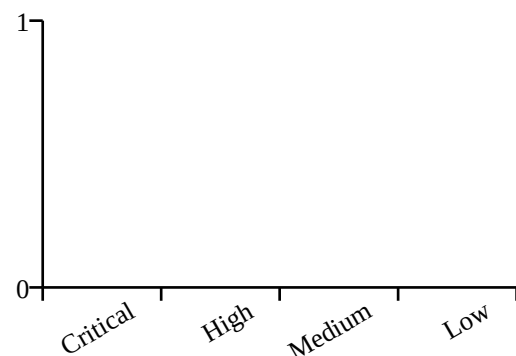
CODE ASSESSMENT

The codebase leverages the Pinocchio framework and demonstrates consistent coding standards with emphasis on modularity and extensibility. Through effective use of Rust traits, the implementation serves dual purposes: providing core functionality while establishing a framework for seamless integration of additional authentication methods. The codebase includes a comprehensive test suite covering all implemented features.

KEY FINDINGS

Notably, our assessment identified no security vulnerabilities within the audited codebase. We provided only minor observations and recommendations for potential enhancements.

SEVERITY DISTRIBUTION



ENGAGEMENT SCOPE

The scope of this security assessment was a full review of the following items:

Item 1: External Signature Program

Link: <https://github.com/Squads-Grid/external-signature-program>

Commit: e500633787f3cb8adc1b93a895dc843818bb9afa

Program ID: ExtSgUPtP3JyKUysFw2S5fpL5fWfUPzGUQLd2bTwftXN

Audit Result:

- **Audited Commit:** 01ed9bcb7e865644c7095e06c085187f4cf80ab9
- **Status:** unverified
- **Comment:** not verified

ISSUES SUMMARY

ID	TITLE	SEVERITY	STATUS
ACC-I1	`check_account` Always Passes Due to Using Stored pubkey Instead of User Input	info	fixed

DETAILED ISSUES

ID	ACC-I1
Title	`check_account` Always Passes Due to Using Stored pubkey Instead of User Input
Severity	info
Status	fixed

Description

In the current implementation, `check_account` derives the account from the account's own ``public_key`` instead of from ``arg.public_key``. This means the check will always succeed, since it's essentially deriving and validating against the same stored value (`self.pubkey`).

There is no direct security issue because signature verification later still uses `account.pubkey` (not ``arg.public_key``) [link](https://github.com/Squads-Grid/external-signature-program/blob/be0563564d538055ec68bc6e53e43c377826c990/src/state/p256_webauthn/trait_impl.rs#L145-L149), but the current check is misleading and doesn't validate whether the user actually passed the correct ``arg.pubkey``.

Location

https://github.com/Squads-Grid/external-signature-program/blob/be0563564d538055ec68bc6e53e43c377826c990/src/state/p256_webauthn/trait_impl.rs#L98-L118

Relevant Code

```
let derive_args = Self::DeriveAccountArgs {
    public_key: self.public_key.to_bytes(),
};
// Check that the account matches the seeds
let account_seeds = Self::derive_account(derive_args)?;
if account_seeds.key.ne(account_info.key()) {
    return Err(ProgramError::InvalidAccountOwner);
}
Ok(account_seeds)
}
```

Mitigation Suggestion

Change `check_account` to derive and validate the account using ``arg.public_key`` so it confirms the user is using the correct ``arg.pubkey``.

Remediation

Fixed in commit 01ed9bcb7e865644c7095e06c085187f4cf80ab9.

APPENDIX

Vulnerability Classification

We rate our issues according to the following scale. Informational issues are reported informally to the developers and are not included in this report.

Severity	Description
Critical	Vulnerabilities that can be easily exploited and result in loss of user funds, or directly violate the protocol's integrity. Immediate action is required.
High	Vulnerabilities that can lead to loss of user funds under non-trivial preconditions, loss of fees, or permanent denial of service that requires a program upgrade. These issues require attention and should be resolved in the short term.
Medium	Vulnerabilities that may be more difficult to exploit but could still lead to some compromise of the system's functionality. For example, partial denial of service attacks, or such attacks that do not require a program upgrade to resolve, but may require manual intervention. These issues should be addressed as part of the normal development cycle.
Low	Vulnerabilities that have a minimal impact on the system's operations and can be fixed over time. These issues may include inconsistencies in state, or require such high capital investments that they are not exploitable profitably.
Informational	Findings that do not pose an immediate risk but could affect the system's efficiency, maintainability, or best practices.

Audit Methodology

Accretion is a boutique security auditor specializing in Solana's ecosystem. We employ a customized approach for each client, strategically allocating our resources to maximize code review effectiveness. Our auditors dedicate substantial time to developing a comprehensive understanding of each program under review, examining design decisions, expected and edge-case behaviors, invariants, optimizations, and data structures, while meticulously verifying mathematical correctness—all within the context of the developers' intentions.

Our audit scope extends beyond on-chain components to include associated infrastructure, such as user interfaces and supporting systems. Every audit encompasses both a holistic protocol design review and detailed line-by-line code analysis.

During our assessment, we focus on identifying:

- Solana-specific vulnerabilities
- Access control issues
- Arithmetic errors and precision loss
- Race conditions and MEV opportunities
- Logic errors and edge cases
- Performance optimization opportunities
- Invariant violations
- Account confusion vulnerabilities
- Authority check omissions
- Token22 implementation risks and SPL-related pitfalls
- Deviations from best practices

Our approach transcends conventional vulnerability classifications. We continuously conduct ecosystem-wide security research to identify and mitigate emerging threat vectors, ensuring our audits remain at the forefront of Solana security practices.